信息安全与数据备份管理规定

文件编号：IT-AQ-2026-008 **版本**：V3.0 **密级**：内部受限 **编制**：信息技术部 **审核**：法务部 **批准**：汤志远 **生效日期**：2026-08-01 **适用范围**：全体员工、外包人员及第三方接入系统

1 总则

为保护公司信息资产的秘密性、完整性与可用性，防范网络与数据安全风险，依据《中华人民共和国网络安全法》《数据安全法》《个人信息保护法》及 GB/T 22239-2019（等级保护 2.0 三级要求），制定本规定。公司 ERP、MES、PLM、知识库均定级为三级系统，须按本规定实施分级保护。

2 数据分类分级

级别	名称	典型数据	存储要求	传输要求	泄露影响
L1	公开	官网介绍、公开白皮书	无限制	明文	无
L2	内部	制度文件、内部通知	内网域控	内网明文	低
L3	机密	设计图纸、报价、客户清单	加密盘＋水印	TLS1.2+	高
L4	绝密	核心算法、并购资料、源代码	隔离网段＋堡垒机	端到端加密	极高

分类分级由数据责任部门在创建时标识，知识库系统按标识自动施加访问控制与水印策略，未标识数据默认按 L3 处理。

3 账号与访问控制

1. **一人一号**：禁止共享账号，系统管理员账号实行”三员分立”（系统管理员、安全管理员、审计管理员）。
2. **最小权限**：按岗位角色授权，权限审批链为申请人→部门负责人→数据属主→IT 安全组。
3. **口令策略**：长度 ≥10 位，须含大写、小写、数字、符号三类以上；90 天强制更换；历史 5 次口令不可重复；连续 5 次失败锁定 30 分钟。
4. **多因素认证**：VPN、堡垒机、ERP 财务模块、代码仓库强制 MFA（TOTP 或硬件令牌）。
5. **离职回收**：HR 发起离职流程后 2 小时内禁用全部账号，30 天后删除；邮箱自动转发须由本人书面申请并经法务审批。
6. **特权账号**：共 24 个，全部纳管于 PAM 系统，会话全程录屏，密码每 24 小时自动轮转。

4 网络安全边界

- 办公网、生产网（OT）、访客网三网逻辑隔离；OT 与 IT 边界部署工业防火墙，仅开放白名单端口（OPC UA 4840、Modbus TCP 502）。
- 生产网禁止访问互联网，禁止接入个人设备；USB 介质须经 IT 病毒扫描站放行。
- 无线访客网带宽限速 10Mbps，隔离内网访问，认证有效期 12 小时。
- 远程运维必须通过零信任网关，禁止直连端口映射；第三方厂商账号有效期不超过 7 天，操作全程审计。

5 终端与移动办公

管控项	基线要求	检查方式	违规处置
全盘加密	BitLocker/LUKS 强制开启	MDM 每日心跳	隔离入网卡顿
防病毒	特征库更新≤7 天，实时防护开启	控制中心日报	自动强制更新
补丁	高危补丁 7 日内、其它 30 日内	WSUS 报表	通报部门负责人
屏幕锁	空闲 5 分钟自动锁屏	MDM 策略	策略不可关闭
外设	未授权蓝牙/网卡禁用	准入系统	阻断并告警
软件	白名单制，盗版软件零容忍	季度盘点	卸载并记录

个人手机处理 L3 及以上数据须使用企业容器化 App，禁止本地保存图片与截图；设备丢失可远程擦除容器数据。

6 数据备份与恢复

6.1 备份策略（3-2-1 原则）

系统	RPO	RTO	全备	增量	副本数	保留期
ERP（Oracle）	15 分钟	2 小时	每周日	每 4 小时+归档日志	3	1 年
MES（SQL Server）	1 小时	4 小时	每日	每小时	3	180 天
PLM/图纸库	4 小时	8 小时	每日	每日	3	2 年
知识库全文与附件	24 小时	24 小时	每周	每日	2	3 年
邮件系统	8 小时	8 小时	每周	每日	2	1 年
代码仓库（GitLab）	1 小时	4 小时	每日	每小时	3	5 年

副本分布为：本地磁盘阵列 1 份、异地（苏州机房）1 份、离线磁带/对象存储不可变副本 1 份。备份介质加密算法 AES-256，密钥由 KMS 管理并分人保管。勒索软件防护要求离线副本采用 WORM（一次写入多次读取）策略，且与生产网完全断开。

6.2 恢复演练

每半年执行一次真实恢复演练，全年覆盖全部核心系统。演练须完成三项指标：备份可用性校验（哈希比对通过率 100%）、RTO 达成率 ≥95%、数据一致性抽检（关键业务表逐行核对）。2026 年上半年演练结果为：ERP 恢复耗时 96 分钟（目标 120 分钟，达标）、MES 恢复耗时 268 分钟（目标 240 分钟，**未达标**，已列入整改，要求数据库集群主备切换脚本优化后复测）。

7 日志与监控

- 关键系统日志集中采集至 SIEM，留存不少于 180 天，安全审计日志不少于 6 个月，涉及等保三级要求的留存 1 年。
- 实时检测规则 42 条，重点覆盖：异地登录、非工作时间批量下载（>200 份/小时）、权限提升、数据库全表导出、勒索软件加密行为特征。
- 告警分级处置：P1（确认入侵）15 分钟响应、P2（高危可疑）1 小时、P3（一般异常）4 小时，处置结果录入 SOAR 工单。
- 每季度出具《安全运营报告》，内容包括事件统计、TOP10 风险、闭环率与整改计划。

8 个人信息与数据出境

员工与候选人个人信息采集遵循最小必要原则，敏感个人信息（身份证、银行卡、生物识别）单独授权，HR 系统访问需二次认证。客户技术资料下载实行审批＋水印＋操作留痕。公司不

涉及重要数据出境；如需向境外客户传输图纸，须先经法务部数据出境合规模块评估并签署标准合同条款。

9 安全事件分级与响应

级别	判定标准	响应团队	通报范围	关闭时限
一级（重大）	核心系统中断>4 小时或数据泄露>10 万人	应急指挥部＋外部支援	董事会、监管	30 天
二级（较大）	单系统失陷、勒索攻击被阻断	安全组全员	总经理、分管副总	15 天
三级（一般）	弱口令、违规外联、误删数据	值班工程师	部门负责人	7 天
四级（轻微）	单个终端病毒、钓鱼邮件被拦截	终端管理员	IT 部内部	3 天

事件处置遵循”发现→抑制→根除→恢复→复盘”五步法。复盘会议须在关闭前召开，形成《事件复盘报告》，包括时间线、根因、失效点、措施与责任人。

10 违规责任

违反本规定造成数据泄露或系统中断的，视情节给予警告、绩效扣减、解除劳动合同处理；涉嫌犯罪的移送司法机关。外包人员违规的，按保密协议追究供应商责任并纳入黑名单。

附录 员工安全行为十条

1. 不在公共聊天工具传输 L3 以上文件；2. 不点击未验证的发件人附件；3. 不使用他人账号或共享密码；4. 离开工位必锁屏；5. 不在生产网设备上插私人 U 盘；6. 不私自搭建外网隧道或代理；7. 软件安装走白名单申请；8. 发现异常立刻报告，不擅自处理；9. 敏感会议资料会后清理白板与打印机；10. 每季度完成安全考试 80 分以上。